

中华人民共和国通信行业标准

YD/T [×××××]—[××××]
[代替 YD/T]

基于公众电信网的体育赛事网络安全实 施指南

Guidelines for network security technology of sports games based on public
telecommunication network

[点击此处添加与国际标准一致性程度的标识]

(报批稿)

[点击此处添加本稿完成日期]

[××××]-[××]-[××]发布

[××××]-[××]-[××]实施

中华人民共和国工业和信息化部 发布

目 次

前言..... II

1 范围..... 1

2 规范性引用文件..... 1

3 术语和定义..... 1

4 概述..... 1

5 赛前安全要求..... 1

 5.1 分析摸底..... 1

 5.2 赛前安全咨询..... 1

 5.3 采购与外包安全..... 2

 5.4 安全工程实施..... 2

 5.5 测试与验收..... 3

 5.6 赛前准备..... 3

6 赛时安全要求..... 3

 6.1 安全值守..... 3

 6.2 安全监测..... 4

 6.3 安全应急..... 4

7 赛后安全要求..... 4

前 言

本文件按照GB/T 1.1-2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》给出的规则起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：西安邮电大学、中国信息通信研究院、陕西省信息化工程研究院、北京奇虎科技有限公司、中国联合网络通信集团有限公司、新华三技术有限公司、中兴通讯股份有限公司、中国信息通信科技集团有限公司、杭州安恒信息技术股份有限公司。

本文件主要起草人：张勇、朱志祥、彭琴、胡键伟、刘国营、张屹、陶冶、万晓兰、霍玉臻、张祺琪、徐雷、孙传闯、吴晨、王佩、任学强、王辉、梁伟、岳玲、魏鹏飞、刘巍然、刘玉梅。

基于公众电信网的体育赛事网络安全实施指南

1 范围

本文件给出了基于公众电信网的体育赛事网络安全领域工作的赛前准备、赛时运行和赛后总结方面的实施指南。

本文件适用于指导基于公众电信网的体育赛事开展网络与信息安全管理、组织与实施工作。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 50326 建设工程项目管理规范

YD/T AAAAA 基于公众电信网的体育赛事网络安全总体要求

3 术语和定义

YD/T AAAAA中界定的术语和定义适用于本文件。

4 概述

体育赛事网络安全实施工作按照体育赛事的阶段分为赛前安全要求、赛时安全要求与赛后安全要求。赛前安全要求包括分析摸底、赛前安全咨询、采购与外包安全、安全工程实施、测试与验收、赛前准备等方面；赛时安全要求包括安全值守、安全监测、安全应急等方面。

5 赛前安全要求

5.1 分析摸底

本项要求包括：

- 应依据体育赛事活动组织的目标分析并明确安全防护对象类型、范围和规则；
- 应准确摸底体育赛事活动涉及的基础设施、信息系统、数据资源的现状；
- 应由指定部门对服务对象进行识别和登记；
- 应摸底和分析已有信息化服务团队的能力、工作范围和管理体系。

5.2 赛前安全咨询

本项要求包括：

- a) 应委托专业的第三方安全服务机构负责体育赛事网络与信息安全咨询与设计工作；
- b) 应对体育赛事所涉及的场馆进行摸底排查，结合体育赛事的特点、规模、影响范围进行风险识别与分析，并根据分析的结果确定信息安全等级保护级别，在相应等级保护基本要求的基础上制定网络与信息安全保障体系的总体安全策略、安全技术框架、安全管理策略、总体建设规划方案和详细设计方案，并形成配套文件；
- c) 应组织体育赛事管理相关部门和安全技术专家对总体安全策略、安全技术框架、安全管理策略、总体建设规划方案和详细设计方案等相关文件的合理性和正确性进行论证和审定，并上报主管部门审核；
- d) 应在规划时对体育赛事信息系统运行所需的带宽和设备的性能进行评估，以保证体育赛事业务高峰期的需要；
- e) 应在体育赛事信息系统需求分析时同步进行系统安全性需求分析，并在体育赛事信息系统规划时同步进行系统安全性规划。

5.3 采购与外包安全

本项要求包括：

- a) 应指定或授权专门的部门负责信息化产品的采购管理工作；
- b) 应在采购前对产品进行选型测试，确定产品的候选范围，并将候选清单下发到相关部门；
- c) 体育赛事信息化产品的采购应选用集中采购模式，以便于统一品牌或统一服务；
- d) 应按照国家 and 行业规定采购信息化产品；
- e) 应采用正版软件或符合开源许可的软件和服务，严禁使用测试版、盗版软件和未经许可使用的软件和服务；
- f) 外包服务商应由体育赛事组织部门统一选择，并应符合国家及行业的相关规定；
- g) 应与外包服务商签订服务合同或协议，明确双方的工作边界、权利以及责任；
- h) 外包服务商不得将服务工作转包。

5.4 安全工程实施

本项要求包括：

- a) 网络与信息安全实施应与体育赛事基础设施建设工作同步进行，建设实施过程应遵循 GB/T 50326-2017 的要求；
- b) 安全实施单位应制定详细的建设实施方案与工程实施管理制度，对建设实施过程进行管理控制；
- c) 应按照设计方案实施网络安全建设，主要内容包括访问控制、DDOS 防护、安全审计、入侵防范、Web 防护、网络病毒防护、漏洞检测等，以确保网络安全方面能够满足相应等级的安全要求；
- d) 应按照设计方案实施主机与系统安全防护建设，包括操作系统安全防护、数据库系统安全防护两个方面，具体内容包括身份认证、安全审计、访问控制、入侵防范、恶意代码防范、终端安全防护等，以确保主机与系统安全能够满足相应等级的安全要求；
- e) 体育赛事信息系统开发商应确保开发过程的安全，并严格按照安全需求设计规范开发相应的安全功能模块；
- f) 体育赛事信息系统上线前应委托赛事组织方认可的安全服务机构进行安全扫描、代码审计、渗透测试、专项后门检查等安全性检测工作，信息系统开放商应根据检测结果进行相应的修改完善，复测通过后才能上线试运行，确保信息系统的安全性符合规范。

5.5 测试与验收

本项要求包括：

- a) 应指定或授权专门的部门负责系统测试与验收的管理工作；
- b) 测试与验收负责部门应在体育赛事网络与信息系统建设完成后委托赛事组织方认可的单位进行安全性评测，并出具安全评测报告；
- c) 赛事组织方认可的测评单位在测试验收前应根据设计方案或合同要求等制订测试验收方案，在测试验收过程中应详细记录测试验收结果，并形成测试验收报告；
- d) 应建立问题跟踪管理机制，对测试过程中发现的问题进行记录，并对问题的解决过程进行跟踪管理，确保测试发现的问题得到及时的修改和加固；
- e) 应组织相关部门和相关人员对系统测试与验收报告进行审定，并签字确认；
- f) 对于直接采购云服务的模式，云服务单位应提供赛事组织方认可的安全检测报告，以证明其网络与信息安全防护能力是否满足要求；
- g) 应对系统的灾备和数据备份能力进行检查，并定期开展演练。

5.6 赛前准备

本项要求包括：

- a) 受委托安全服务机构应在体育赛事开赛至少三个月入场实施安全服务；
- b) 应针对赛时安全服务的事务，组织各相关方参与人员进行管理和技术的培训，培训内容包括管理制度、流程、专业技能等；培训完成后应进行相应的考核，并将考核结果记录并保存；
- c) 应针对赛时安全服务的事务处置进行演练，确保流程和技术的可靠性，并根据演练的结果对管理流程和技术操作手册进行修订；
- d) 安全应急预案应通过有效途径向相关人员、角色或部门进行下发，并在体育赛事开赛至少组织三次应急预案培训和演练，并根据培训和演练的结果对应急预案进行修订，确保应急预案的可执行性；
- e) 应与应急部门沟通协调，必要时组织多部门联合安全应急演练，为体育赛事赛时期间的安全应急响应提供保障。

6 赛时安全要求

6.1 安全值守

本项要求包括：

- a) 应委托专业的第三方安全服务机构负责体育赛事赛时期间的安全保障服务工作；
- b) 受委托安全服务机构应建立体育赛事期间的安全服务管理体系，包括安全服务管理制度、流程、操作手册等，并组织入场服务人员进行培训和演练，确保安全服务管理体系的有效可靠；
- c) 受委托安全服务机构应对重要网络和信息系统的实行 7×24 小时安全保障服务；
- d) 应建立有效的赛时安全保障沟通机制，可使用电话、无线对讲、内部即时通信、短信等手段，确保安全保障各相关方沟通的及时性和安全性；
- e) 应建立现场调度指挥中心，针对安全保障过程中的各类事件进行及时的人员、物资等的协调与配备，确保各类事件能够得到及时的解决。

6.2 安全监测

本项要求包括：

- a) 根据体育赛事安全监测预警的需求和相关标准规范的要求，建立并完善体育赛事安全监测预警制度，通过相应的监测技术和工具，能够自主进行安全监测；
- b) 应明确监测对象、监测指标、监测频率，监测对象包括系统运行状态、网络、物理环境、业务应用状态等；
- c) 应能对体育赛事信息资产的可用性进行监测，包括网络可用性、服务器可用性、数据库可用性、系统可用性等，能够在可用性不满足要求时进行告警；
- d) 应能对体育赛事通信系统进行监测，包括网络通信、无线通信、卫星通信等，并能够在通信系统出现故障时及时进行告警；
- e) 应能对提供互联网服务的体育赛事信息系统进行页面和内容的篡改进行监测，并在篡改发生时及时进行告警；
- f) 应对安全监测数据进行集中管理，利用大数据技术进行关联、分析和预测，通过与威胁情报的联动，实现动态安全感知和响应处置；
- g) 应能对互联网上体育赛事舆情进行监测分析，包括网站、论坛、微信、QQ等相关平台，并能够在监测到舆情热点时进行告警提示，提高舆情处置的效率；
- h) 赛前每月、赛时期间每周应对安全监测的情况进行评估总结，向相关人员和角色报告体育赛事网络与信息系统的的状态。

6.3 安全应急

本项要求包括：

- a) 应建立赛时安全应急团队，配备足够的技术人员，并建立由各层面专家组成的安全应急专家组，确保能够在安全事件发生时提供足够的技术支持；
- b) 应为核心关键系统配备专门的应急保障小组，配备专业的技术人员；
- c) 应根据安全事件级别限定安全应急响应和处置的时间要求，确保对体育赛事的影响降到最低；
- d) 应为安全事件应急响应建立沟通汇报机制，明确不同级别安全事件上报的对象和范围。

7 赛后安全要求

本项要求包括：

- a) 体育赛事结束后应开展资源和工作移交工作，明确移交工作内容和 workflows，确保赛事结束后顺利进入安全运行维护；
- b) 体育赛事结束后，受委托安全服务机构应对安全服务期间的安全服务情况进行书面总结；
- c) 赛后安全服务报告，内容至少包括：安全事件数量、事件描述、原因和影响分析、处置方式等相关信息。